

Arquitectura de software, funcional y objetivo de producción

Diseño consolidado de la plataforma Nexo Klar: componentes actuales, separación multiempresa, modelo operativo, seguridad, datos, integraciones y arquitectura productiva.

Propósito del informe

Servir como documento de referencia para directorio, equipo técnico, integrador cloud y potenciales clientes empresariales. Diferencia capacidades implementadas en el repositorio de servicios que necesitan contratación y configuración externa.

Referencia	Estado
Producto	Nexo Klar Cloud v7.7.0
Validación técnica	123 pruebas automatizadas correctas
Código oficial	Repositorio GitHub y carpeta oficial de Escritorio
Fecha	12 de agosto de 2026
Clasificación	Confidencial · uso técnico, comercial y de implementación

Dictamen resumido. Nexo Klar tiene una base de software funcional, integrada y multiempresa. Para operar comercialmente como SaaS necesita completar la infraestructura externa, las evidencias de continuidad y los proveedores productivos de seguridad e integración.

1. Resumen ejecutivo

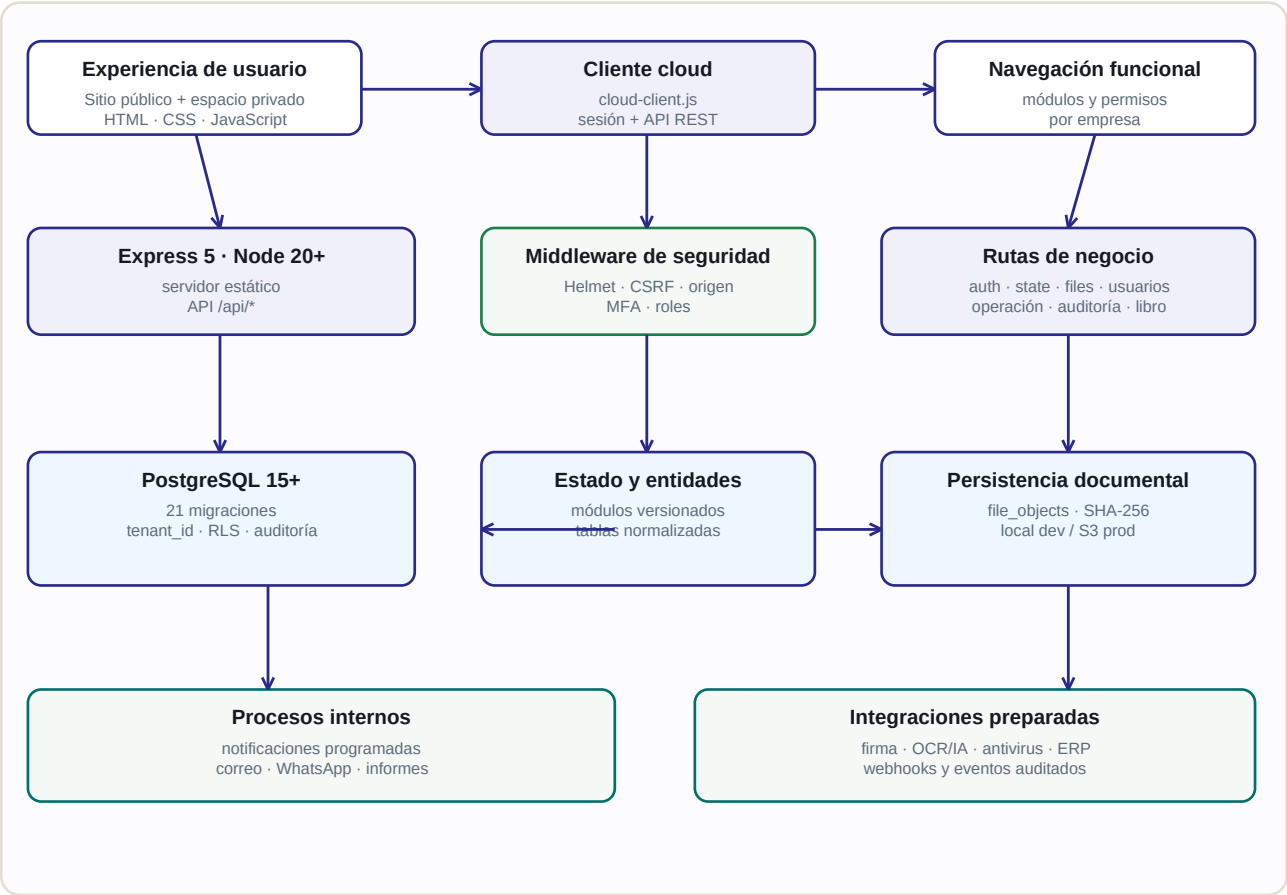
Nexo Klar está diseñado como una plataforma SaaS de control operacional para empresas de servicios. Su arquitectura conecta la relación comercial, las personas, los recursos, la ejecución, el cumplimiento y el gobierno de datos en un espacio aislado por empresa.

Capa	Responsabilidad	Estado actual
Experiencia	Sitio público y aplicación privada, navegación por módulos, formularios, filtros, reportes y control visual.	Implementada
Aplicación	Servidor Express, API REST, validación, roles, CSRF, MFA, jobs y reglas de negocio.	Implementada
Datos	PostgreSQL, migraciones, RLS, integridad, auditoría, módulos versionados y entidades normalizadas.	Implementada / requiere instancia productiva
Documentos	Carga controlada, hash, deduplicación, descarga autorizada y conectores de antivirus/S3.	Preparada para producción
Integraciones	Correo, WhatsApp, firma, OCR/IA, ERP y acreditación mediante configuraciones por empresa.	Preparada / requiere proveedor
Operación cloud	Docker, Compose, plantilla ECS, health/readiness y variables de entorno productivas.	Preparada / requiere AWS

Principio de diseño: la información crítica permanece en la empresa, pero se conecta con el cliente, contrato, orden de servicio, persona, recurso y documento correspondiente. No debe depender de planillas aisladas ni de conocimiento personal.

2. Diagrama de arquitectura de software actual

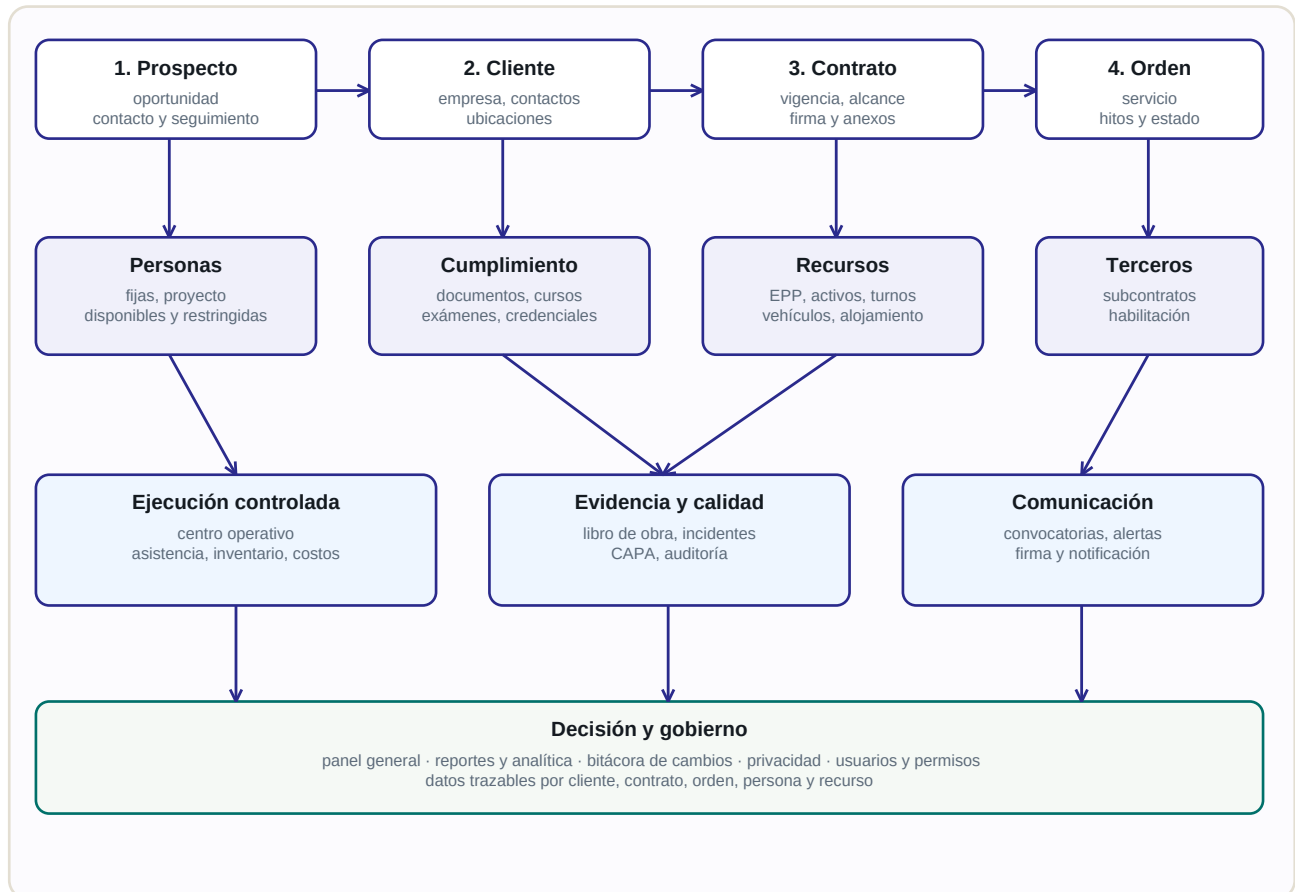
El navegador carga el sitio público o el espacio privado. La API centraliza autenticación, autorización, datos, archivos, eventos y reglas. La separación por empresa se aplica en la aplicación y en la base de datos.



Implementación actual: interfaz HTML/CSS/JavaScript modular, Express 5 sobre Node.js 20+, PostgreSQL 15+, rutas REST, jobs internos y almacenamiento documental. No es una aplicación React/Vite.

3. Arquitectura funcional del producto

El valor de Nexo Klar está en mantener un flujo continuo. La relación comercial define el contexto; las personas y recursos se habilitan; la ejecución genera evidencia; los paneles consolidan decisiones y control.



Regla funcional: una orden de servicio puede operar solo cuando sus personas, requisitos, recursos, alojamiento, vehículos, EPP y evidencias necesarias están asociadas y vigentes. Las brechas se reflejan como alertas, restricciones o pendientes operativos.

4. Dominios funcionales y responsabilidades

Dominio	Módulos principales	Interacción clave
Centro de control	Panel general, alertas, gestión de personal por proyecto, centro operativo.	Consolida disponibilidad, brechas, prioridades y estado de ejecución.
Relación comercial	Prospectos, clientes, contratos, firmas, órdenes de servicio.	Cliente → contrato → orden; contexto para personas, costos y documentos.
Capital humano	Personas, turnos y asistencia, EPP, formación, exámenes, salud y restringidos.	Habilita o restringe a cada persona según requisitos y asignación.
Gestión operacional	Comunicaciones, vehículos, alojamientos, credenciales, terceros, incidentes.	Asigna recursos a órdenes y registra ejecución, tiempo y evidencia.
Activos e inventario	Maquinaria, instrumentos, herramientas, EPP, materiales, bodegas, movimientos y mantenimiento.	Controla disponibilidad, costos, préstamos, vida útil y reposición.
Cumplimiento y calidad	Documentación corporativa, habilitación del cliente, auditoría, CAPA, libro de obra.	Registra requisitos, revisión, firma, hallazgos, compromisos y cierre.
Gobierno	Reportes, configuración, importación/exportación, usuarios, bitácora, privacidad, administración de clientes.	Controla permisos, parámetros, trazabilidad, respaldo y operación SaaS.

5. Arquitectura multiempresa y separación completa

Nexo Klar sigue un modelo multi-tenant con una misma plataforma y datos aislados por empresa. El tenant no se decide en el navegador: surge desde la sesión autenticada y se aplica en cada transacción de base de datos.

Mecanismo	Diseño técnico	Resultado
Identidad de tenant	La sesión enlaza usuario, tenant, rol y estado de cuenta.	No se aceptan tenant_id arbitrarios desde la interfaz.
Autorización	Middleware authenticate, allowRoles, requireMfa, requireCsrf y requireOrigin.	Cada acción exige identidad, permiso, MFA y origen válido.
RLS	withTenant() fija app.current_tenant_id en la transacción; PostgreSQL aplica políticas RLS y FORCE RLS.	Defensa en profundidad incluso ante consultas incompletas.
Archivos	Cada objeto se registra con tenant_id y key tenants/{tenantId}/objects/{sha}.	Descargas y eliminaciones se autorizan por empresa.
Configuración	Catálogos, marca, módulos, alertas e integraciones quedan por tenant.	Empresa A parametriza sin modificar Empresa B.
Auditoría	Cambios, acciones, integraciones y fallas contienen contexto de tenant y usuario.	Soporte y trazabilidad por cliente.

Validación de aislamiento

La aceptación productiva exige probar con al menos tres empresas: crear datos equivalentes, intentar consulta cruzada, descarga de archivos, cambios de configuración, importación/exportación y URLs manipuladas. El resultado esperado es cero acceso cruzado.

6. Datos, persistencia e integridad

Elemento	Diseño actual	Reglas relevantes
PostgreSQL	21 migraciones versionadas; pool de conexiones con SSL estricto en producción.	Migración ordenada, readiness y transacciones por tenant.
Estado modular	tenant_module_state conserva colecciones funcionales y versión por módulo.	Evita que cambios en un módulo sobrescriban otro; conflicto 409 cuando existe desactualización.
Entidades normalizadas	Trabajadores, requisitos, catálogos, estado operativo, vínculos, historial, control de planes y soporte.	Permite integración, auditoría, reportes y evolución gradual.
Integridad	RUT, contratos, proyectos, asignaciones, habitaciones, entregas, vehículos y relaciones.	Unicidad por empresa, fechas coherentes y referencias existentes.
Auditoría	audit_log, entity_change_history, operational_events e integration_events.	Usuario, fecha, entidad, acción, resumen, evidencia y contexto.
Importación/exportación	JSON completo y CSV por entidad con validación.	Detecta duplicados, formato, fechas y referencias antes de confirmar.

Reglas verificadas por pruebas: se rechazan RUT duplicados incluso con distinto formato, asignaciones duplicadas, contratos/proyectos de otra empresa, alojamientos superpuestos, patentes/series duplicadas y entregas EPP inconsistentes.

7. Seguridad de aplicación y protección de datos

Control	Implementación en código	Condición productiva
Contraseña	scrypt con salt único y política mínima de 12 caracteres.	Mantener política, recuperación controlada y revisión de cuentas comprometidas.
MFA	TOTP, códigos de recuperación y MFA_REQUIRED en producción.	Enrolamiento obligatorio, resguardo de recovery codes y soporte seguro.
Sesiones	Token aleatorio, hash SHA-256 en BD, cookie HttpOnly, Secure y SameSite Strict.	HTTPS real y revocación ante reinicio de contraseña o incidente.
HTTP/API	Helmet, CSP actual, no-store en API, CSRF, origen permitido, roles y límites.	WAF, revisión CSP, pentest y monitoreo de ataques.
Archivos	MIME permitido, máximo 25 MB, SHA-256, deduplicación, estado de malware.	Antivirus HTTPS obligatorio, cuarentena y alertas.
Secretos	AES-256-GCM para secretos de integración por tenant.	Secrets Manager, IAM mínimo, rotación y prohibición de secretos en Git.
Privacidad	Módulo de privacidad, actividad de tratamiento, consentimientos y solicitudes.	Gobierno real de Ley 21.719: responsables, retención, derechos y protocolo de brechas.

8. Documentos e integraciones

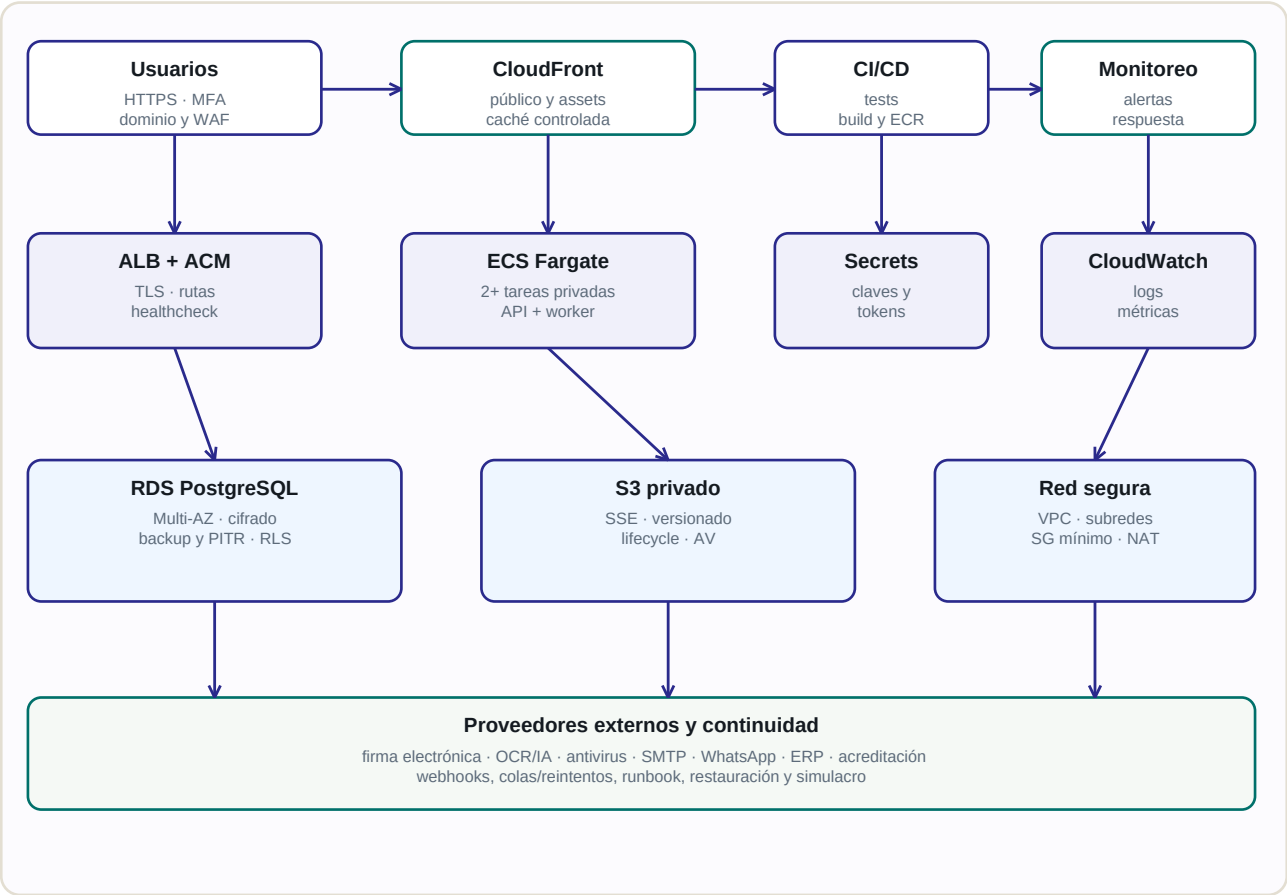
Los documentos están diseñados como evidencia controlada. La aplicación conserva archivos, estado y contexto; proveedores externos agregan capacidades de seguridad, firma y validación, sin reemplazar la decisión humana.

Servicio	Función integrada	Modelo de operación
S3 privado	Documentos, contratos, certificados, fotos y evidencias.	Carga vía API, metadatos, hash, tenant_id, cifrado, versionado y acceso autorizado.
Antivirus	Evalúa archivos antes de liberarlos.	Producción rechaza carga si el servicio AV no está configurado o disponible.
OCR / IA	Extrae fechas, emisor, RUT, QR, campos y señales de consistencia.	Resultado y score auditados; revisión humana final obligatoria.
Firma electrónica	Contratos, anexos, actas y libro de obra.	Solicitud por correo/celular, webhook firmado, estado y evidencia.
SMTP / WhatsApp	Alertas, convocatorias, vencimientos, firmas e informes.	Configuración por empresa, destinatarios, historial de envío y errores.
ERP / acreditación	Costos, órdenes, facturación y habilitación cuando exista API oficial.	Eventos idempotentes, reintentos, auditoría y aprobación técnica/legal.

Restricción importante: no se debe automatizar un portal de cliente o mandante sin API oficial, autorización contractual y validación de seguridad. Los conectores deben usar webhooks, claves segregadas y auditoría.

9. Diagrama de arquitectura productiva objetivo

Esta es la arquitectura recomendada cuando Nexo Klar opere con clientes. Mantiene el acceso público reducido al perímetro HTTPS y deja aplicación, datos y archivos en servicios privados.



Regla de producción: los contenedores no tienen volumen compartido ni secretos en imagen; PostgreSQL y S3 son las fuentes de persistencia; AWS administra red, cifrado, escalamiento, recuperación y monitoreo según configuración aprobada.

10. Diseño de despliegue y operación AWS

Componente	Diseño objetivo	Prueba de aceptación
DNS, ACM y ALB	Dominio HTTPS, certificado administrado, listener 443 y redirección 80→443.	TLS válido, health check operativo y cabeceras seguras.
VPC y seguridad	ALB público; ECS y RDS privados; SG por mínimo privilegio; 2 AZ.	No hay RDS/ECS público; solo ALB llega a la API.
ECS Fargate	Mínimo dos tareas, health /api/health, readiness /api/ready, rolling deploy.	Escalamiento, rollback y reemplazo automático de tarea fallida.
RDS PostgreSQL	PostgreSQL 15+, Multi-AZ, cifrado, backups y point-in-time recovery.	Restauración en ambiente aislado medida y documentada.
S3	Block public access, SSE, versionado, lifecycle, IAM por Task Role.	Archivo solo descarga con autorización; se valida versionado y borrado lógico.
Secrets Manager	Database URL, clave tenant, métricas, AV, firma, OCR y mensajería.	No hay secreto en repositorio, imágenes, logs o navegador.
CloudWatch	Logs estructurados, métricas, dashboards y alarmas.	Alarma 5xx, jobs fallidos, latencia o readiness llega al responsable.
CI/CD	Tests, build, escaneo, ECR, migración única, staging y despliegue aprobado.	No se libera un cambio sin pruebas y smoke test.

11. Diseño operativo de extremo a extremo

Etapa	Flujo técnico-funcional	Control
Ingreso	Usuario de una empresa inicia sesión con MFA y recibe sesión segura.	tenant, rol, permiso, MFA, CSRF y origen.
Configuración	Administrador define catálogos, responsables, requisitos y módulos de su empresa.	Configuración aislada y auditada por tenant.
Gestión comercial	Se crea prospecto, cliente, contrato y orden de servicio.	Vigencias, responsables, documentos y estado comercial.
Habilitación	Se vinculan personas, formación, salud, EPP, recursos y documentos.	Matriz de requisitos, alertas y restricción automática.
Ejecución	Centro operativo coordina trabajo; se registran movimientos, asistencia, libro, incidentes y CAPA.	Historial, evidencia, fechas, responsables y firma cuando aplique.
Comunicación	Sistema programa correo, WhatsApp, firma, avisos y reportes.	Consentimiento, proveedor, lock, reintento y resultado.
Control	Paneles, alertas y reportes consumen datos por empresa, cliente, contrato y orden.	Permisos, filtros, bitácora y exportación validada.
Continuidad	Plataforma monitorea salud, errores, backups e integraciones.	Alarmas, runbook, restauración y post-incidente.

Escalabilidad: una empresa puede tener configuraciones y módulos distintos sin afectar otras. Para solicitudes de personalización comercial, la recomendación es usar catálogos, reglas, campos configurables y feature flags por tenant; no forks de código por cliente.

12. Pruebas, calidad y trazabilidad

Cobertura verificada	Resultado
Pruebas automatizadas	123 correctas: seguridad, migraciones, autorización, datos, módulos, QA de menú, flujo operativo, libro de obra, archivos, inventario, EPP, terceros, importación y arquitectura.
Multiempresa	Pruebas separan usuarios, datos operacionales, marcas, integraciones, catálogos y módulos por empresa.
Integridad	Pruebas rechazan duplicados críticos, relaciones cruzadas y registros huérfanos.
Producción	Validación de variables exige HTTPS, secretos fuertes, MFA, S3, token de métricas y antivirus HTTPS.
Calidad visual y vocabulario	Pruebas de paridad entre versión local y productiva, navegación agrupada, filtros de personas, sistema visual y terminología unificada.
Pendiente externo	Pruebas reales en AWS, proveedor AV, firma, OCR, WhatsApp, SMTP, monitoreo, restauración y pentest.

Importante: las pruebas de código validan comportamiento interno. Las pruebas de infraestructura y proveedores deben ejecutarse con recursos reales antes de vender la operación como completamente productiva.

13. Matriz de preparación productiva

Prioridad	Acción	Resultado esperado
P0	Crear dev, staging y producción independientes; configurar AWS, DNS, TLS, IAM, RDS, S3 y Secrets Manager.	Entorno productivo aislado y reproducible.
P0	Habilitar MFA, antivirus, backups, restauración, CloudWatch, alertas y runbook.	Servicio seguro, recuperable y monitoreado.
P0	Ejecutar prueba de aislamiento con tres empresas, prueba de recuperación y pentest externo.	Evidencia de seguridad y continuidad antes de datos reales.
P1	Conectar firma, OCR, QR, emisor, foto e integraciones con proveedores contratados.	Flujo documental inteligente con revisión humana y trazabilidad.
P1	Desacoplar worker de jobs y usar EventBridge/SQS cuando aumente volumen.	Notificaciones y tareas escalables, con reintentos robustos.
P1	Extender entidades normalizadas y APIs por dominio para BI e integraciones de alto volumen.	Reportes y conectores más eficientes y mantenibles.
P2	Agregar SSO corporativo, WAF avanzado, rotación automática de secretos y evaluación Aurora.	Madurez enterprise según demanda y SLA.

Conclusión final

Nexo Klar está diseñado como una plataforma SaaS multiempresa con una base funcional sólida. La arquitectura de software, datos, seguridad y módulos ya soporta la operación integrada. La siguiente fase debe concentrarse en ejecutar la arquitectura cloud objetivo, validar proveedores reales y reunir evidencia de continuidad para ofrecer el servicio en producción con confianza.